Report Scenario 2

REVISIONI DEL DOCUMENTO

Versione	Data	Autore	Descrizione	Parti modificate
1.0	4/12/2023	Francesco Golisciano	Emissione del documento	Tutte

LISTA DI DISTRIBUZIONE

Distribuito a	Azienda/Ente	Ruolo
MAURO ANDREOLINI	Fastweb	Cyber coaching

Sommario

Executive summary
1 Introduzione
2 Fasi operative
3 Analisi dei processi
4 Analisi file system
5 Analisi traffico di rete
6 Ricostruzione del quadro d’insieme
7 Estrazione payload
8 Ricostruzione file
9 Raccomandazioni DevSecOps
10 Valutazione del rischio
11 IOC
12 Next Steps

Executive summary

È stata rilevata l’esfiltrazione di un file dalla macchina vittima verso un server DNS sotto il controllo dell’attaccante, tramite interrogazioni DNS di tipo TXT. Il processo bash /opt/exfiltrator/exfiltrator si riattiva ogni trenta secondi e invia porzioni del file, codificate in Base64, dentro i nomi di host del dominio akvz.com. Il file ricostruito è un messaggio che contiene delle credenziali. Le tecniche osservate mappano su MITRE ATT&CK (T1059.004, T1071.004, T1048.003, T1027). Rischio complessivo: Alto. Azioni immediate: arresto del processo, isolamento dell’host, blocco delle query verso IP-attaccante e rotazione delle credenziali esfiltrate.

Nota: questo report è una rielaborazione di uno scenario simulato utilizzato a fini formativi. Gli indirizzi sono indicati come IP-vittima e IP-attaccante. Nome dell’account, password e autore del repository sono stati anonimizzati.

1 Introduzione

Con il presente documento si vuole illustrare le fasi di analisi svolte nel contesto offerto dallo Scenario 2 facente parte del corso “Security Analyst” di Fastweb Digital Academy (3a edizione, maggio-giugno 2023). Nello scenario corrente, un attaccante, dopo aver violato il sistema vittima, esfiltra dati verso un proprio sistema usando il protocollo DNS. Il protocollo DNS permette di gestire contenuti testuali tramite le interrogazioni di tipo TXT; l’ampio utilizzo che in genere si fa del suddetto protocollo permette all’attaccante di essere meno individuabile tra le innumerevoli richieste.

L’architettura di riferimento dello Scenario 2 è mostrata in Figura 1. La macchina attaccante esfiltra file tramite il protocollo DNS verso una macchina sotto il suo controllo. Il traffico è offuscato per impedire un riconoscimento immediato dei file trasferiti. La macchina vittima ha trenta account dedicati agli utenti. Si è stabilita una connessione alla macchina vittima tramite protocollo SSH, usando le credenziali assegnate. L’indirizzo IP della macchina vittima, fornito dal docente, è IP-vittima.

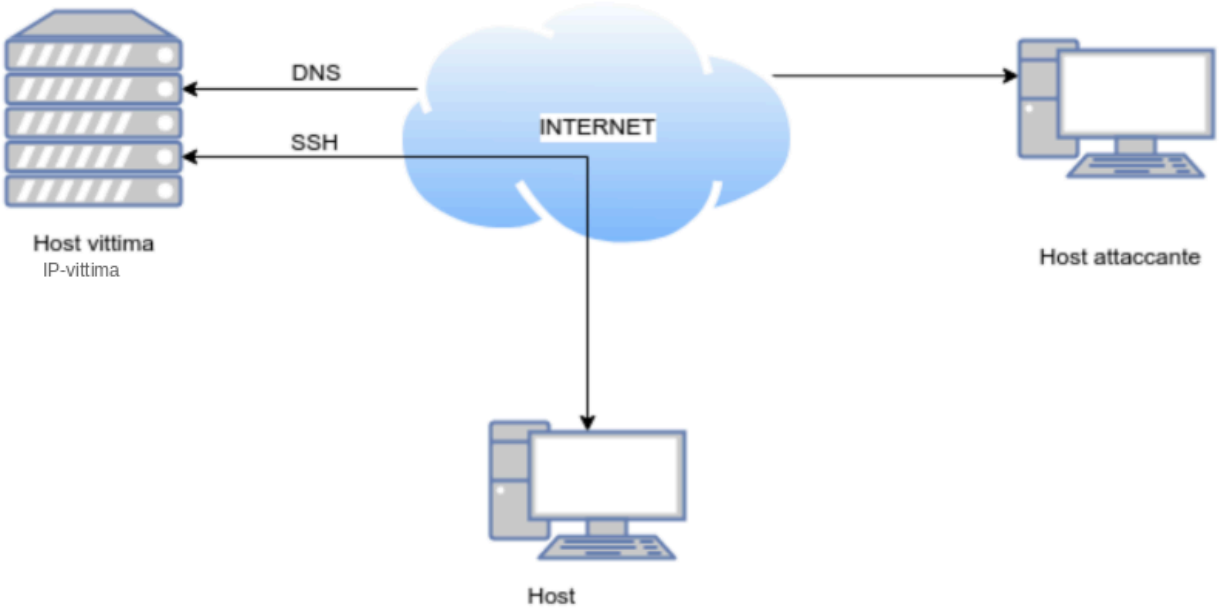


Figura 1: Architettura dello scenario

2 Fasi operative

L’analisi è stata condotta seguendo il diagramma operativo mostrato in Figura 2. Esso è costituito da diverse fasi volte ad acquisire informazioni sul sistema compromesso e sul traffico di rete, identificare anomalie specifiche, ricostruire il meccanismo di esfiltrazione e decodificare i dati.

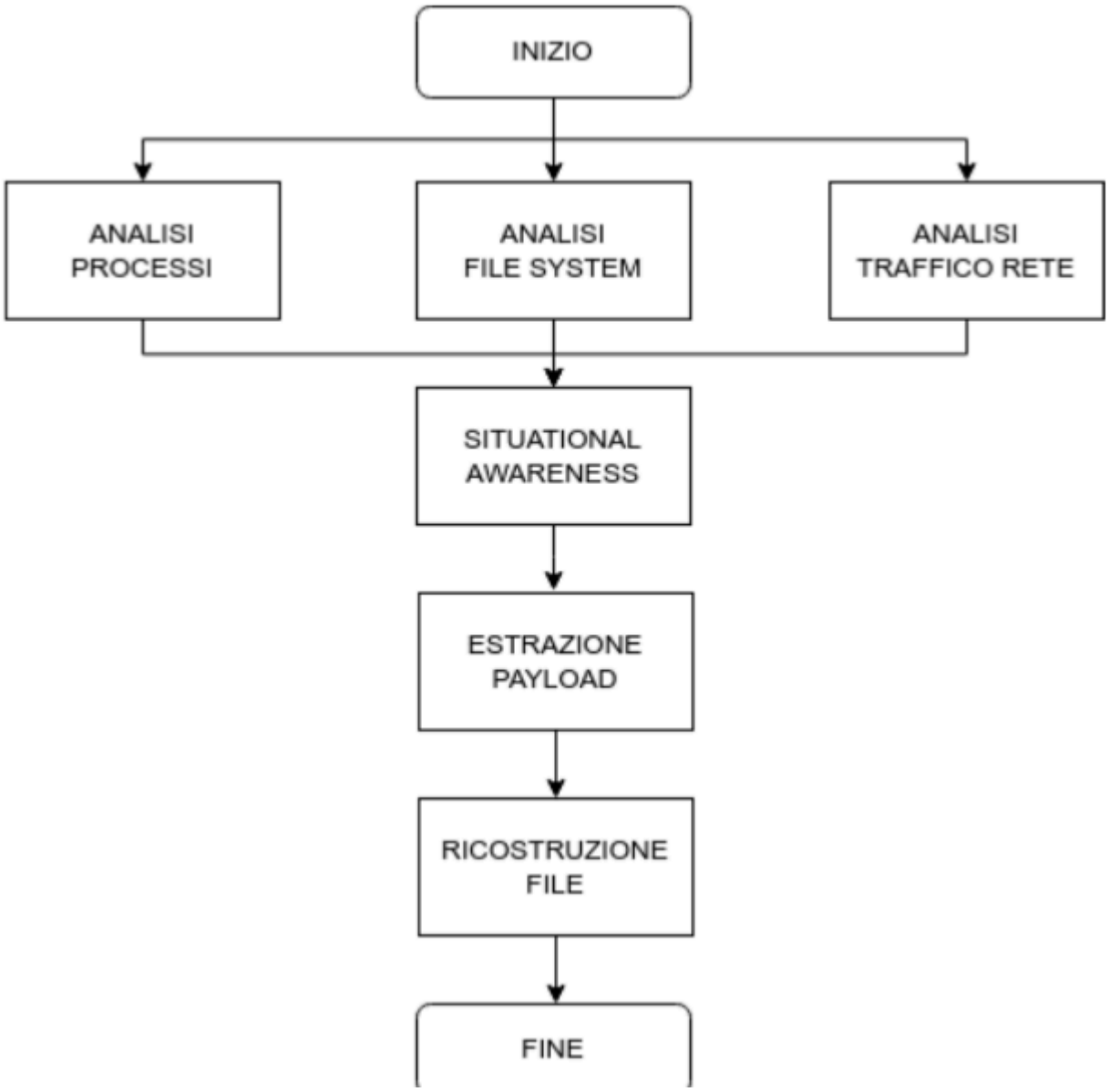


Figura 2: Diagramma di flusso operativo

La Tabella 1 descrive le diverse attività coinvolte in ciascuna fase del diagramma di flusso operativo. Ogni fase è presentata con il proprio nome, una descrizione sintetica delle attività svolte ed un elenco di obiettivi.

Tabella 1: Descrizione delle attività

Fase	**Descrizione attività**	**Obiettivi**
ANALISI PROCESSI	Si analizzano i processi in esecuzione sulla macchina vittima. Si identificano processi con nomi e/o parametri sospetti.	Individuare il processo che esfiltra i dati.

Fase	Descrizione attività	Obiettivi
ANALISI FILE SYSTEM	Si analizza il file system della macchina vittima. Si identificano i file aperti da eventuali processi sospetti.	Leggere il sorgente dell’esfiltratore (ed eventuali file da lui aperti) per capire meglio come agisce.
ANALISI TRAFFICO RETE	Si cattura il traffico su una interfaccia di rete specifica e si produce una traccia PCAP. Si trasferisce la traccia localmente e la si analizza.	Capire come viene esfiltrato il file.
RICOSTRUZIONE DEL QUADRO D’INSIEME	Si ricostruisce l’intero evento.	Avere un quadro più chiaro possibile di come funziona l’esfiltratore.
ESTRAZIONE PAYLOAD	Si estrae il dato esfiltrato dalla traccia PCAP.	Ottenere lo stesso dato che l’attaccante riceve sulla sua macchina.
RICOSTRUZIONE FILE	Si analizza il dato ottenuto e si cerca di capire se è offuscato e/o cifrato in qualche modo. Si prova a ricostruire il file esfiltrato.	Determinare le operazioni di decodifica e/o decifratura propedeutiche alla ricostruzione del file. Ottenere il file esfiltrato dall’attaccante.

3 Analisi dei processi

In Figura 3 è illustrato l’elenco dei processi in esecuzione, prodotto con il comando seguente:

```
ps faxu
```

Il comando ps faxu stampa l’intero albero dei processi in modo esteso.

Nell’output si notano alcuni processi con il nome sospetto exfiltrator. Tali processi sembrano essere script BASH, poiché sono lanciati dal comando bash. Uno di questi script dorme per trenta secondi (si noti il processo sleep 30). Probabilmente l’intero meccanismo di esfiltrazione si attiva ogni trenta secondi.

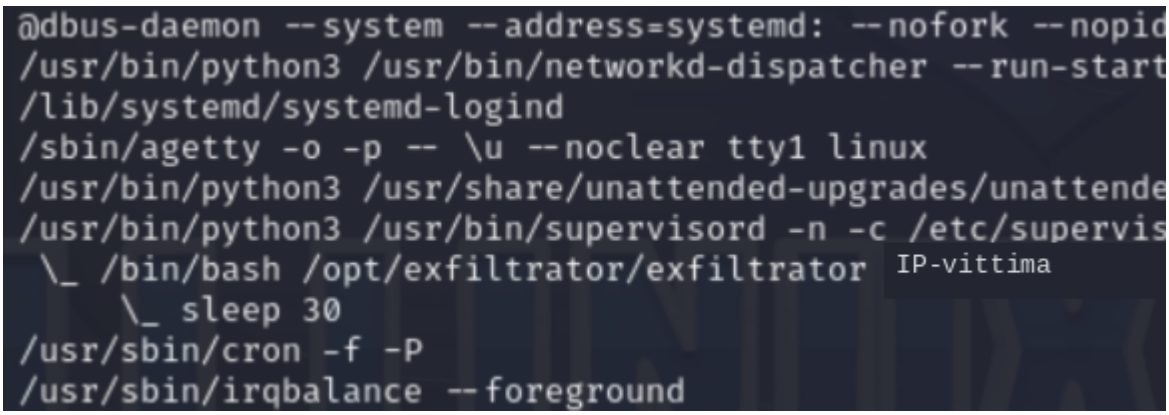


Figura 3: Elenco dei processi in esecuzione

4 Analisi file system

Dall’output dei processi si evince che lo script exfiltrator è installato nella directory /opt/exfiltrator. Come è possibile vedere in Figura 4, nella directory /opt sono presenti due directory di nome DnsTunnel e exfiltrator. Il tentativo di accesso tramite il comando cd /opt/exfiltrator fallisce; si ottiene il messaggio di errore “Permission denied” che indica la mancanza di permessi di accesso sufficienti per l’esame di tale directory.

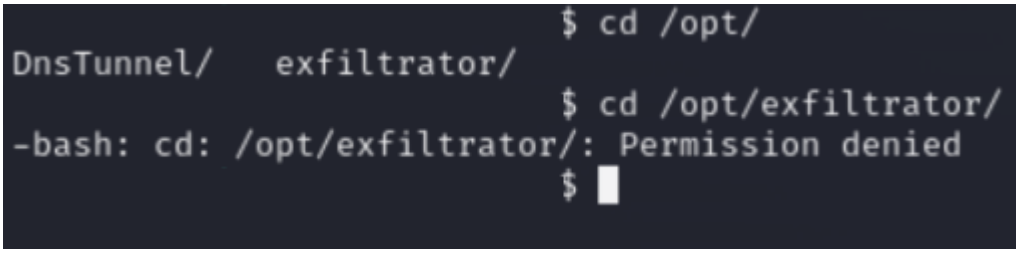


Figura 4: Directory /opt

Analizzando le precedenti directory in Figura 5 ci si rende conto che appartengono all’utente john. La directory exfiltrator non concede permessi di lettura, al contrario della directory DnsTunnel.

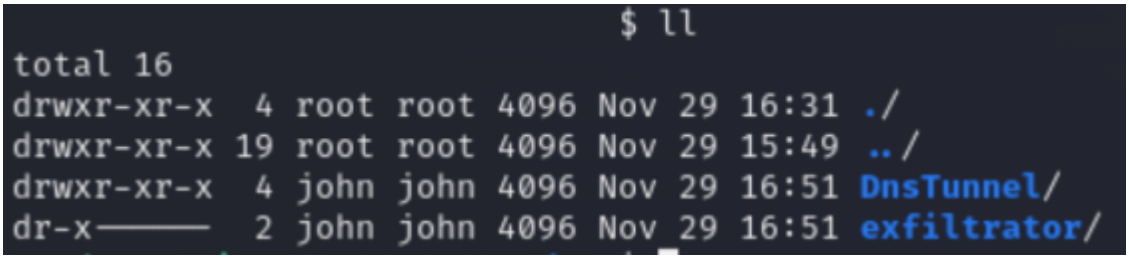


Figura 5: Proprietari delle directory

Come è possibile vedere in Figura 6, si accede alla directory DnsTunnel contenente diversi file con estenzione .py, tra cui il file sospetto exfiltration.py. Inoltre la directory nascosta .git lascia intendere la presenza di un repository GIT. È pertanto possibile analizzare tutte le modifiche intermedie del software (nominate nel seguito commit).

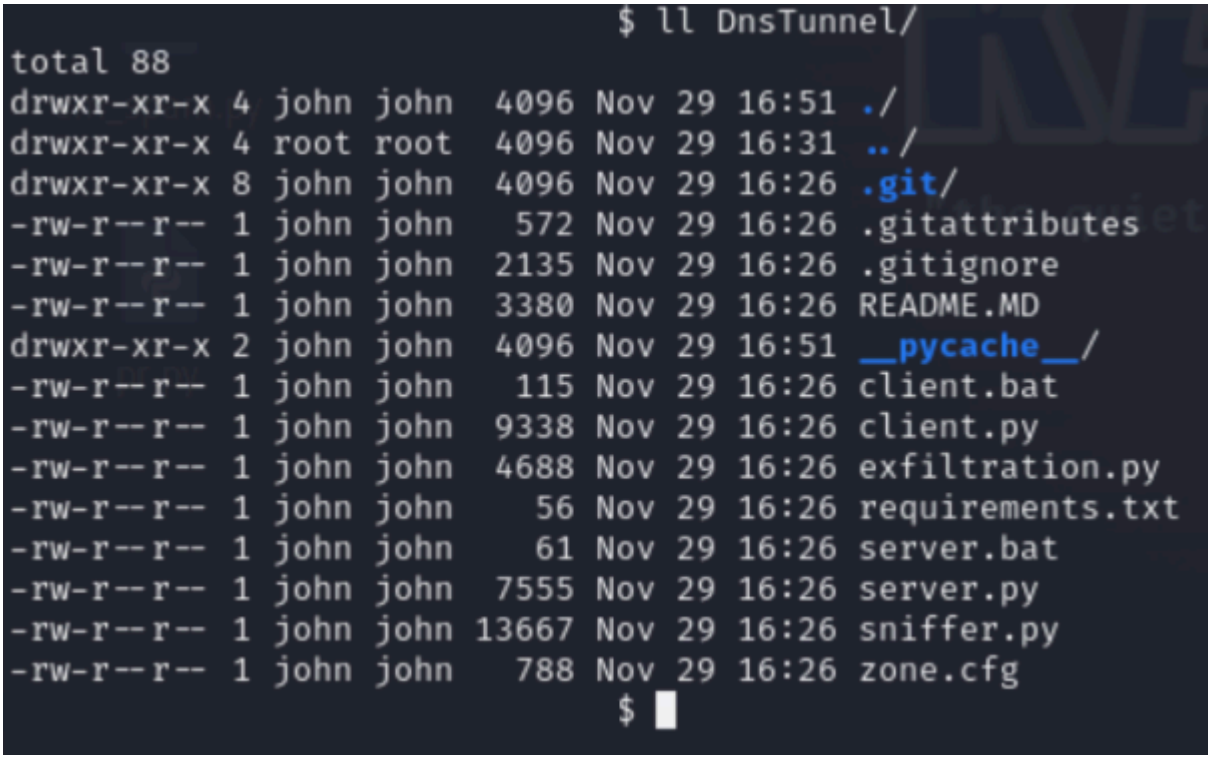


Figura 6: Contenuto della directory DnsTunnel

Si enumera il repository GIT, avendo cura di abilitare prima l’opzione safe.directory che consente la visione dei commit anche ad un utente non proprietario della directory:

```
git config --global --add safe.directory /opt/DnsTunnel
```

Dopodiché si elenca la storia dei commit con il comando git log, avendo cura di personalizzare la visualizzazione del paginatore less tramite la variabile di ambiente LESS:

```
LESS=-Mr git log
```

In Figura 7 e in Figura 8 si possono notare azioni sospette in cui compaiono i nomi dei file exfiltration.py e server.py trovati precedentemente nella directory DnsTunnel, a carico dell’autore del repository.

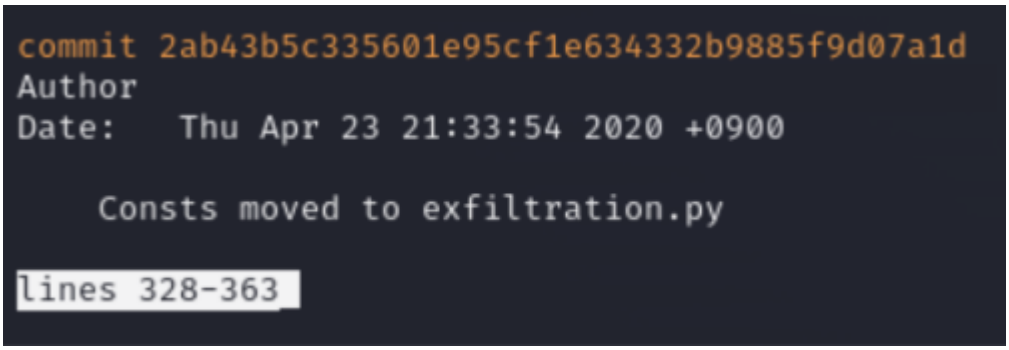


Figura 7 Individuazione del commit relativo al file exfiltration.py

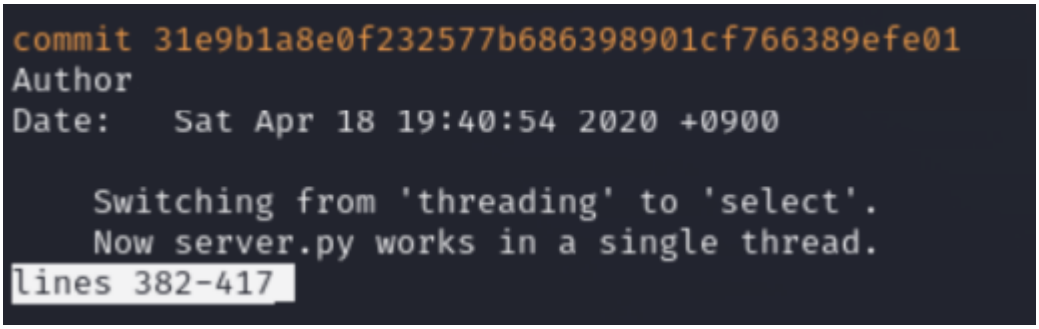


Figura 8 Individuazione del commit relativo al file server.py

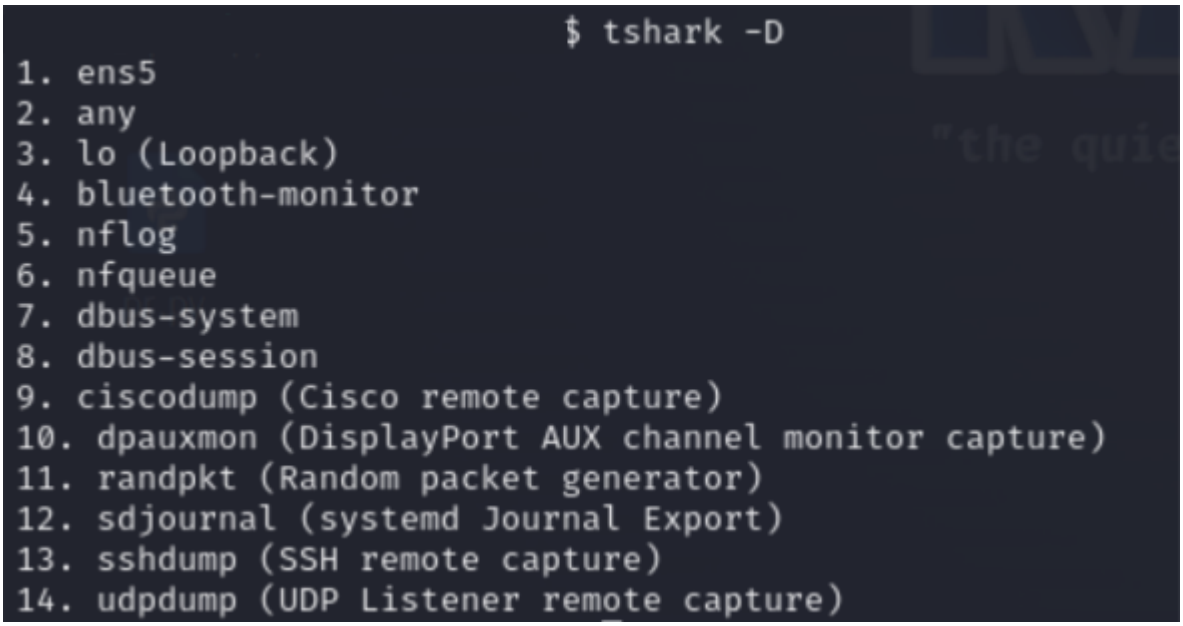
In Figura 9 si può notare quello che molto probabilmente è il meccanismo di esfiltrazione, ovvero l’invio di file tramite interrogazioni DNS.



Figura 9: Individuazione del commit Sending files via DNS query messages

5 Analisi traffico di rete

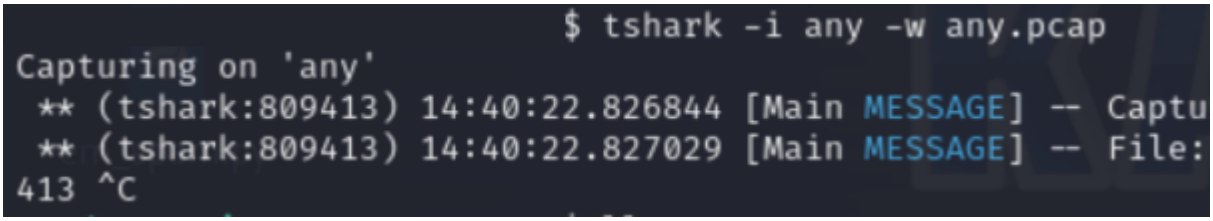
Si procede con la cattura di una traccia di traffico in formato PCAP tramite il software tshark. Si elencano le interfacce disponibili alla cattura con il comando tshark -D. In Figura 8 si possono visualizzare le interfacce di rete disponibili per la cattura del traffico di rete.



Interfacce di rete disponibili

Si avvia la cattura del traffico live any salvando la traccia nel file any.pcap:

```
tshark -i eth0 -w eth0.pcap
```



Avvio della cattura

Si interrompe la cattura del traffico con la combinazione di tasti CTRL-c.

Si copia localmente la traccia di traffico any.pcap, eseguendo ad esempio il comando seguente dalla postazione locale dell’analista, come in Figura 12.

```
scp <utente>@IP-vittima:any.pcap .
```

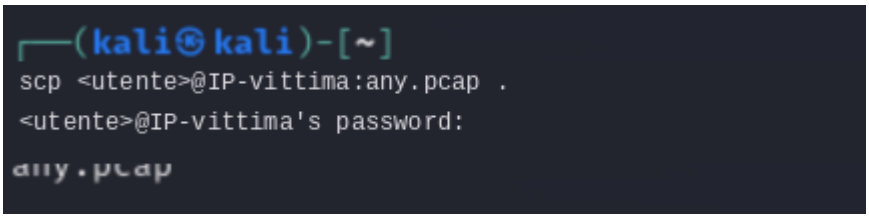


Figura 12 copia locale della traccia pcap

Si analizza la traccia di traffico any.pcap con il comando wireshark any.pcap, il quale permette di visualizzare il suddetto file con il software Wireshark, con l’obiettivo di individuare la comunicazione con l’attaccante. Selezionando il menu “Statistiche” e la funzione “Gerarchia di protocolli” si nota che il 5.8% delle richieste è di tipo DNS (si veda la Figura 13).

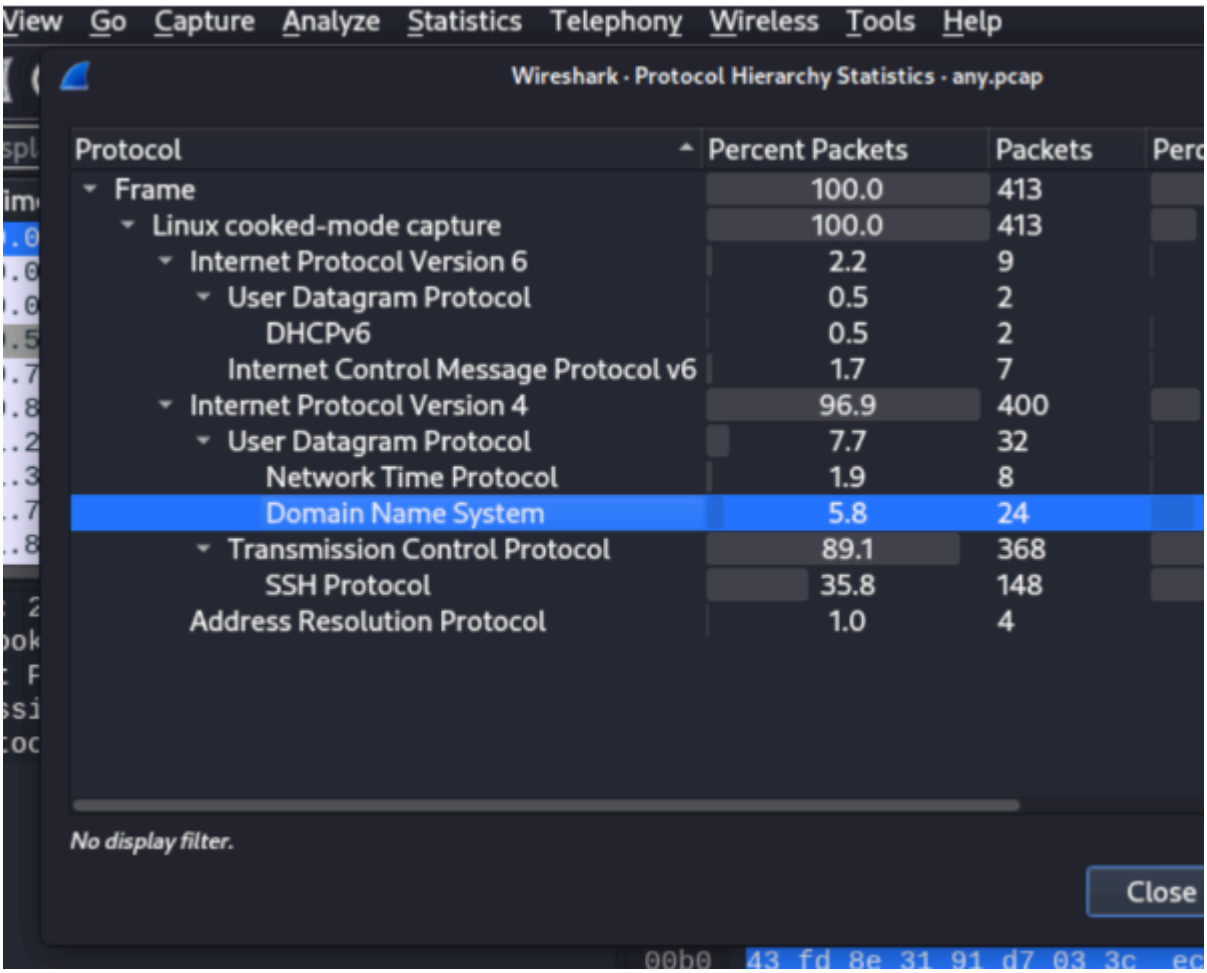


Figura 13: Gerarchia dei protocolli

Successivamente si seleziona il menu “Statistiche” e la funzione “Conversazioni”. Come si evince dalla Figura 14, due macchine con indirizzi IP-vittima e IP-attaccante colloquiano fra loro tramite il protocollo DNS. Nello specifico, la macchina avente indirizzo IP-vittima (ovvero, la vittima) invia alla macchina avente indirizzo IP-attaccante (ovvero, l’attaccante) diversi blocchi dati di dimensione pari a 723 byte, ben superiore a quella delle più comuni richieste di tipo A (risoluzione di indirizzi IPv4 a partire dal nome). Ciò è molto sospetto e deve indurre ad una analisi più approfondita del contenuto delle conversazioni.

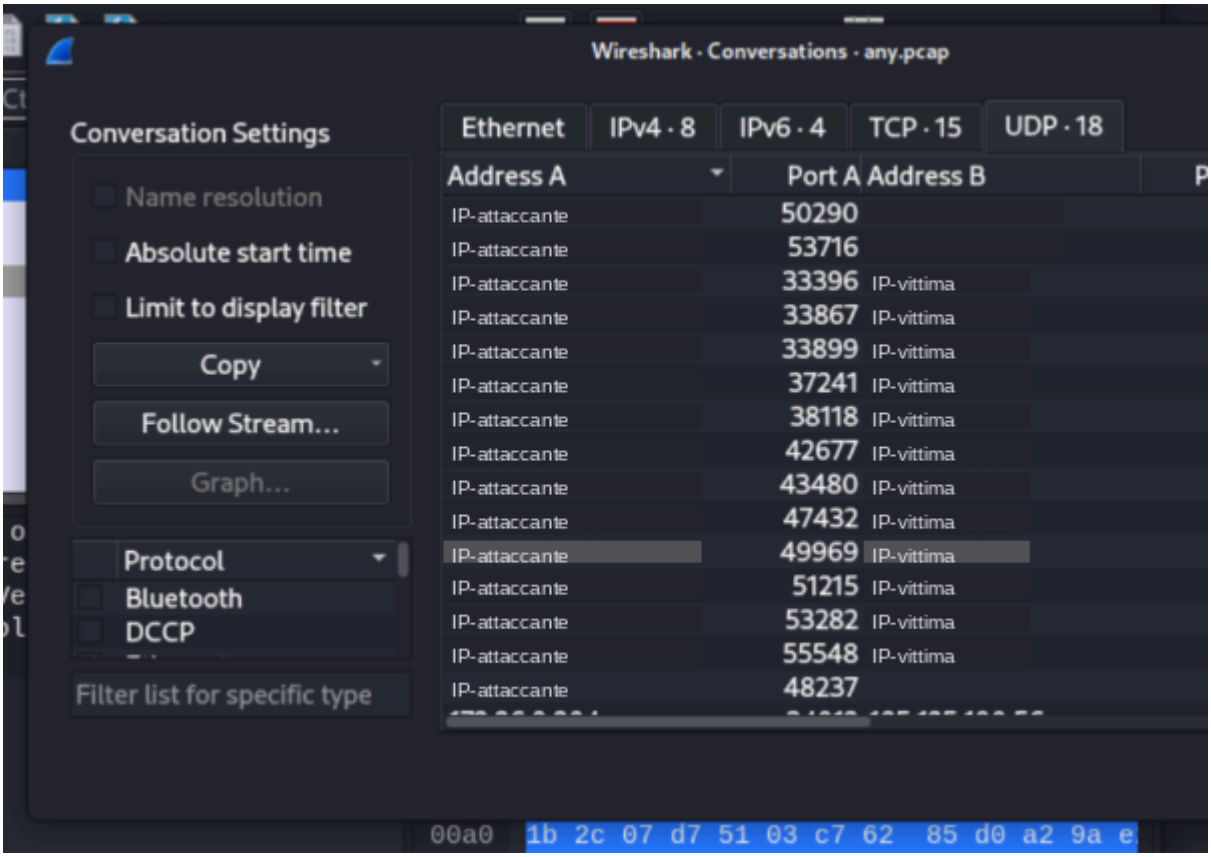


Figura 14: Conversazioni

Si opta per la selezione dell’intero traffico DNS, ad esempio applicando “dns” come filtro nella barra di ricerca (si veda la Figura 15).

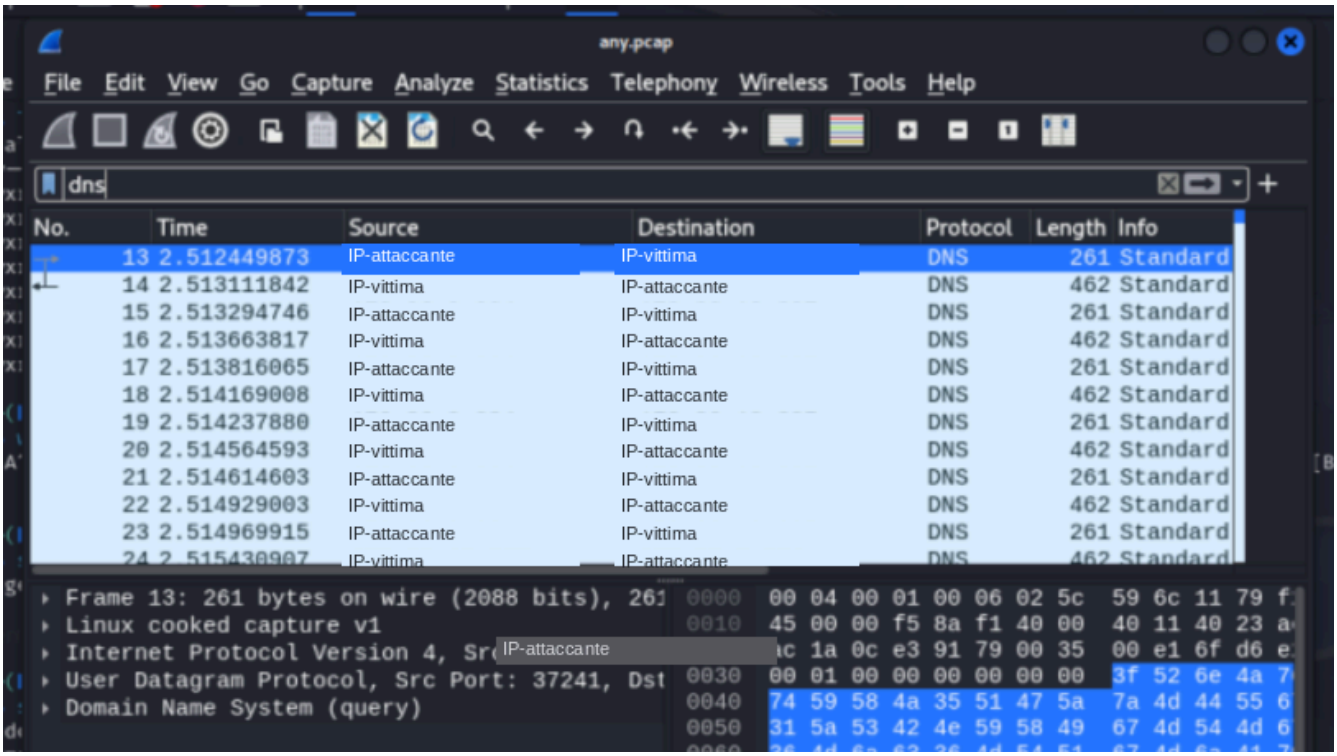


Figura 15: Creazione di un filtro di visualizzazione sul protocollo DNS

Si visualizzano i frame selezionati. In ognuno di questi frame sono presenti interrogazioni DNS di tipo TXT. In Figura 16, nel riquadro di dettaglio del frame si può notare un nome di dominio akvz.com e un nome di host improbabile, probabilmente una stringa codificata in qualche modo. Queste caratteristiche si ripetono in ogni interrogazione DNS.

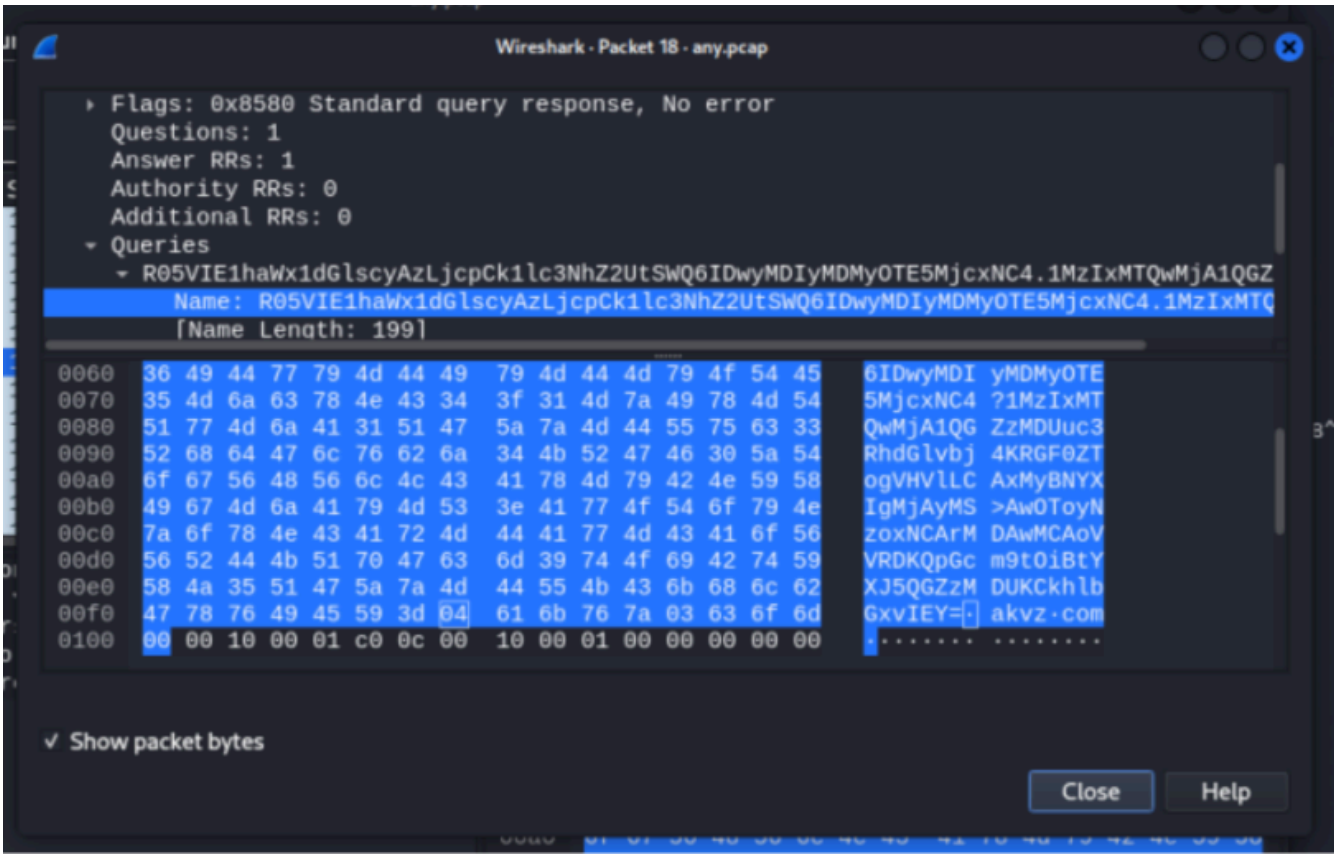


Figura 16: Interrogazioni DNS di tipo TXT al dettaglio

6 Ricostruzione del quadro d’insieme

In questa sezione si riassumono brevemente le principali evidenze scoperte finora.

- Un processo di nome exfiltrator (associato al file /opt/exfiltrator) sta generando traffico DNS verso il server DNS IP-attaccante
- Il processo si riattiva ogni trenta secondi
- Il traffico generato dallo script consiste in interrogazioni DNS di tipo TXT (inusuali) con nomi di host apparentemente codificati in qualche modo

Alla luce delle precedenti osservazioni si può formulare la seguente

IPOTESI: i nomi degli host nella interrogazioni DNS sono, in realtà, porzioni del file codificate.

7 Estrazione payload

Esaminando più accuratamente il nome dell’host, si scopre che i caratteri utilizzati nella sua codifica sono, tra gli altri, a-z, A-Z, 0-9 e =. Si potrebbe dedurre una possibile codifica Base64, se non fosse per

i punti (invalidi in tale codifica) e per il nome di dominio in chiaro. La presenza del carattere = alla fine del nome dell’host sembrerebbe tuttavia corroborare questa ipotesi.

Si effettua un esperimento: si eliminano sia il nome di dominio sia i punti, dopodiché si decodifica la stringa da Base64. Il risultato è presentato in Figura 17; sembra si tratti di una porzione di una mail attraverso la quale si richiedono le credenziali per accedere ad un nuovo server. Evidentemente il meccanismo di offuscamento dello script exfiltrator codifica porzioni di un file in nomi di dominio di livello N (N=3, 4, 5). Ripetendo la procedura di decodifica su tutti i nomi degli host contenuti nelle interrogazioni DNS di tipo TXT ed unendo i risultati in chiaro si dovrebbe ottenere l’intero file in chiaro.

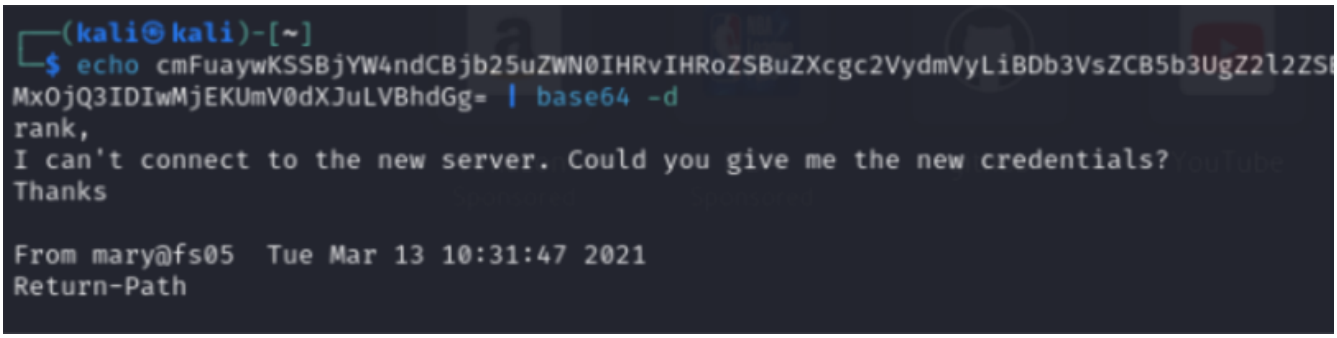


Figura 17

8 Ricostruzione file

La ricostruzione manuale del file, ottenuta estraendo tutti i nomi di host, decodificandoli e concatenando i risultati è lunga, tediosa e soggetta a errori. È di gran lunga preferibile automatizzare queste operazioni tramite lo script di shell seguente:

```
for line in $(tshark -r any.pcap -Y "dns.qry.type == 16 and ip.src == IP-attaccante" -T fields -e dns.qry.name | sed -e "s/\.akvz.com//" | sed -e "s/\.//"); do echo $line | base64 -d; done
```

In Figura 18 è illustrato l’output del comando precedente, che consente di ricostruire il contenuto integrale del file esfiltrato.

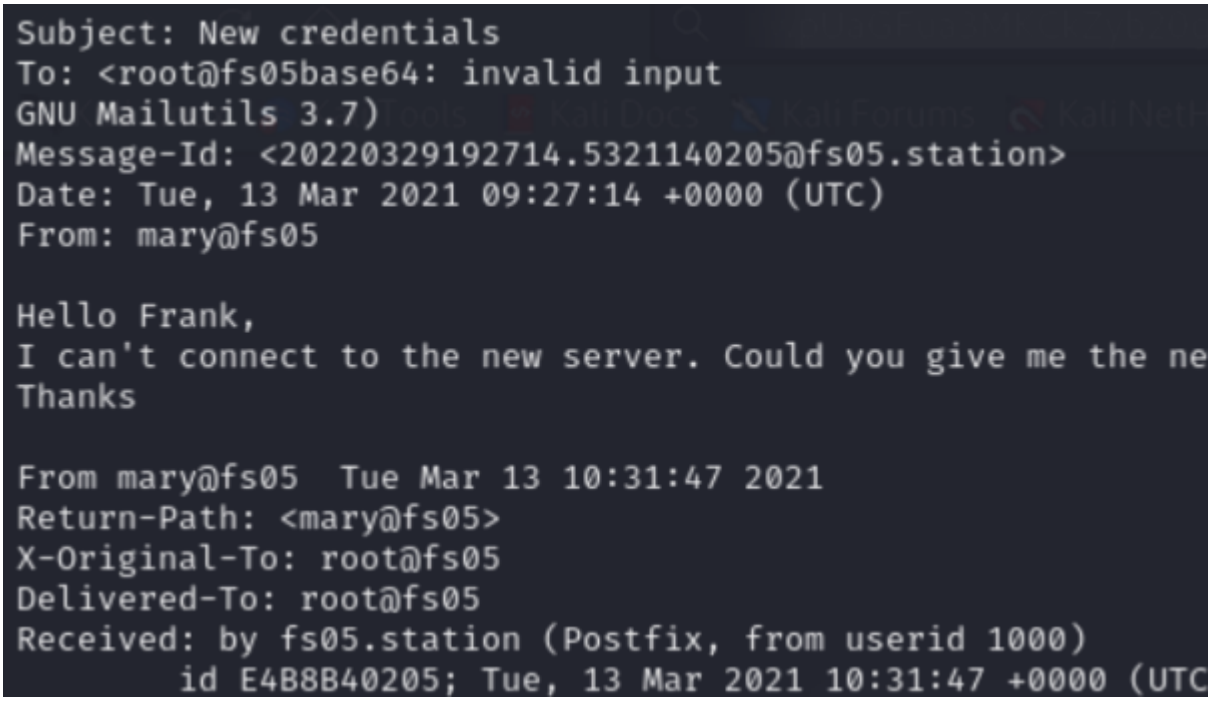


Figura 18: File esfiltrato ricostruito

9 Raccomandazioni DevSecOps

- High - Contenimento: arrestare il processo exfiltrator, isolare l’host e bloccare il DNS verso IP-attaccante e il dominio akvz.com. (Owner: Sysadmin)
- High - Detection: registrare le query DNS (nome, tipo, dimensione) e allertare sulle interrogazioni TXT con nomi molto lunghi o di dimensione prossima a 723 byte. (Owner: Security Team)
- Medium - Hardening: consentire il DNS in uscita solo verso resolver autorizzati. (Owner: Infra)
- Medium - Integrità: baseline e controllo delle modifiche su /opt, in particolare script e repository non previsti (exfiltrator, DnsTunnel). (Owner: DevSecOps)
- Low - Preventive: sinkhole per i domini appena osservati e allerta sulla frequenza delle query TXT. (Owner: Infra)

10 Valutazione del rischio

- Impatto: Alto (esfiltrazione di un messaggio contenente credenziali).
- Probabilità: Media (DNS in uscita non filtrato).
- Rischio complessivo: Alto.
- Priorità: intervento immediato sull’host e sul DNS in uscita.

11 IOC

Indicatori di compromissione

File sospetti	Processi osservati	Endpoint	Payload	MITRE
/opt/exfiltrator/exfiltrator /opt/DnsTunnel/exfiltration.py /opt/DnsTunnel/server.py	bash /opt/exfiltrator/exfiltrator sleep 30	query DNS TXT verso akvz.com server IP-attaccante	nomi di host in Base64 messaggio ricostruito con credenziali	T1059.004 T1071.004 T1048.003 T1027

12 Next Steps

- Immediate: arresto del processo, isolamento dell’host, blocco di akvz.com e di IP-attaccante, rotazione delle credenziali contenute nel file ricostruito.
- Breve: logging DNS, regole sulle query TXT anomale, DNS in uscita solo verso resolver autorizzati.
- Medio: baseline di /opt, regole SIEM su tipo e dimensione delle query, controllo dei repository comparsi fuori dai percorsi previsti.